

Speed Review — D8: Privacy e GDPR

Modulo molto denso, alta priorità. Sapere a memoria: art. 5 (7 principi), art. 6 (6 basi), art. 9 (dati sensibili), sanzioni a fasce.

1. Basi

- **GDPR** = Reg. UE 2016/679 (in vigore 25/05/2016, applicabile **25/05/2018**) + **Codice Privacy** (D.Lgs. 196/2003).
- Tutela i **diritti delle persone fisiche**. NON si applica a: **persone giuridiche**, **dati anonimi**, attività **personali/domestiche**, autorità per fini di prevenzione reati.
- **Ambito territoriale**: titolare/responsabile **stabilito nell'UE** (ovunque tratti); oppure non stabilito UE ma tratta dati di **interessati nell'UE** (offerta beni/servizi o monitoraggio).

Definizioni

- **Dato personale** (art. 4): info su persona fisica **identificata o identificabile**.
- **Trattamento**: qualsiasi operazione su dati personali.
- **Profilazione**: trattamento automatizzato per valutare aspetti personali.
- **Pseudonimizzazione**: dato ancora personale (riconducibile con info aggiuntive separate) → **resta sotto GDPR**.
- **Anonimizzazione**: dato non più personale → **fuori dal GDPR**.

Soggetti

Soggetto	Ruolo
Titolare	Determina finalità e mezzi (per proprio conto)
Responsabile	Tratta per conto del titolare , su istruzioni; nominato con contratto (art. 28)
Interessato	Persona fisica cui si riferiscono i dati
Autorizzato/Designato	Opera sotto l'autorità del titolare, nessuna autonomia

Responsabile del trattamento (data processor) **DPO** (Data Protection Officer).

2. Principi e basi giuridiche

Art. 5 — 7 principi

1. Liceità, correttezza, trasparenza
2. **Limitazione della finalità**
3. **Minimizzazione**
4. Esattezza
5. **Limitazione della conservazione**
6. Integrità e riservatezza
7. **Responsabilizzazione** (*accountability*) — il titolare deve **dimostrarlo**

Art. 6 — 6 basi giuridiche (basta UNA)

1. **Consenso**
2. **Esecuzione di un contratto**
3. **Obbligo legale**
4. **Interessi vitali**
5. **Interesse pubblico / pubblici poteri**

6. **Legittimo interesse** (no per le autorità pubbliche; bilanciamento con i diritti dell'interessato)

Art. 25 — by design / by default (*segnalato dalla prof*)

- **Privacy by design**: protezione integrata fin dalla **progettazione**.
- **Privacy by default**: per impostazione predefinita solo i **dati necessari**; accesso non aperto a numero indefinito di persone.

3. Consenso, dati sensibili, diritti

- **Consenso**: dimostrabile dal titolare; **chiaramente distinguibile**; **revocabile** in ogni momento (con la stessa facilità). Servizio condizionato a consenso non necessario → consenso **non libero**.
- **Minori**: lecito da **16 anni** (UE); Italia **14 anni**; mai sotto 13.

Art. 9 — categorie particolari (dati sensibili)

Vietato trattare: origine razziale/etnica, opinioni politiche, convinzioni religiose/filosofiche, appartenenza sindacale, dati **genetici**, **biometrici** *intesi a identificare univocamente*, salute, vita/orientamento sessuale. - Eccezioni A–J (consenso esplicito, lavoro, interesse vitale, ecc.). > “Intesi a identificare univocamente” → solo i **biometrici**, non tutti i sensibili.

Diritti dell'interessato (artt. 15–22)

Accesso (15), Rettifica/Integrazione (16), **Cancellazione/oblio** (17), Limitazione (18), **Portabilità** (20), **Opposizione** (21).

4. Adempimenti, breach, DPO, sanzioni

- **Registri** (art. 30): obbligo se >250 dipendenti, **oppure** rischio / non occasionale / categorie particolari.
- **Data breach** (artt. 33-34): titolare notifica al **Garante entro 72 ore** (salvo improbabile rischio); comunicazione all'**interessato** se **rischio elevato** (non serve se dati cifrati). Il responsabile informa il titolare “senza ingiustificato ritardo”.
- **DPIA** (art. 35): obbligatoria se trattamento a **rischio elevato** (prima di procedere).
- **DPO** (artt. 37-39): obbligatorio se autorità pubblica, monitoraggio sistematico su larga scala, categorie particolari su larga scala. Indipendente, **non riceve istruzioni**, no conflitto d'interesse.
- **Trasferimenti extra UE**: decisione di adeguatezza (art. 45) → garanzie adeguate (BCR/SCC, art. 46) → deroghe (art. 49). UE-USA: Safe Harbor → Privacy Shield → **Data Privacy Framework** (2023).

Sanzioni (art. 83) — due fasce

Fascia	Violazioni	Massimo
Bassa	obblighi titolare/responsabile (art. 25, 30, DPO)	10M€ o 2% fatturato
Alta	principi (art. 5), basi (art. 6), diritti (15-22), trasferimenti	20M€ o 4% fatturato

- **Garante**: autorità indipendente, **4 membri** eletti dal Parlamento, mandato **7 anni non rinnovabile**.

Trappole MC

- **Titolare** (finalità e mezzi) **Responsabile** (per conto del titolare) **DPO** (controllo indipendente). Triplo confronto, errore frequente.

- **Pseudonimizzazione** = dato ancora personale (GDPR si applica); **anonimizzazione** = fuori dal GDPR. Il quiz li scambia.
 - Data breach: **72 ore** al Garante (non all'interessato — a quello “senza ritardo se rischio elevato”).
 - Comunicazione all'interessato **non dovuta** se i dati erano **cifrati**.
 - “Intesi a identificare univocamente” → solo **biometrici**.
 - Basi giuridiche: bastano **una** delle 6. Il legittimo interesse **non vale** per le autorità pubbliche.
 - Minori Italia: **14 anni** (UE 16; mai sotto 13).
 - Sanzioni: **2%/10M** (bassa) vs **4%/20M** (alta). Si prende il **maggiore** tra fissa e percentuale.
 - Garante: **7 anni non rinnovabile**, 4 membri.
 - GDPR NON si applica a persone giuridiche e dati anonimi.
-

Da aggiungere dopo le simulazioni: